Transaction Binding Security for Policy-Bound Authorization Tokens

Formal Definitions and Proofs for the SPT-Txn Framework

Rudolf Jacobus Coetzee

Violet Sky Security SEZC
Cayman Islands

rudi@violetskysecurity.com

This paper formalizes the cryptographic foundations of the
Sovereign Policy Token Transaction (SPT-Txn) Framework.
Related systems specification: draft-coetzee-oauth-spt-txn-tokens-00
Preprint: DOI: 10.5281/zenodo.18917439

Abstract

Authorization tokens in distributed systems are typically context-free: a cryptographically valid token carries no binding to the specific transaction for which it was issued, enabling reuse and cross-context presentation attacks that are undetectable at the cryptographic layer. This gap is acute in regulated financial infrastructure and cross-domain authorization protocols, where transaction-scoped enforcement is a hard requirement. While IETF Internet-Draft `draft-coetzee-oauth-spt-txn-tokens` [5] defines a systems architecture for policy-bound transaction tokens within the Sovereign Policy Token Transaction (SPT-Txn) Framework, no formal cryptographic security model or proof exists for the binding property it relies upon.

We provide the first such model. We define the syntax of a *policy-bound transaction token scheme* over a formal transaction context space $\mathcal{C}$, and introduce three game-based security properties: *transaction binding (TB)*, capturing resistance to both forgery and cross-context reuse; *existential unforgeability under chosen-context attack (EUF-CCA)*, isolating pure forgery resistance; and *unlinkability (UNL)*, capturing token pseudonymity. We establish the strict implication $\mathsf{TB} \implies \mathsf{EUF\text{-}CCA}$ and identify the fundamental tension between unlinkability and auditability in this setting.

We present a construction $\Pi[\Sigma, H]$, parameterized by any EUF-CMA-secure signature scheme Σ and a random oracle H, and prove that it achieves transaction binding security with a tight reduction:

$$\mathsf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda) \;\leq\; \mathsf{Adv}_{\Sigma}^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) \;+\; \frac{(q_s + q_H)^2}{2^\lambda}.$$

The reduction is tight and requires no rewinding. EUF-CCA security follows as a corollary. We discuss scope limitations, a concrete instantiation via EdDSA over Ed25519 aligned with the IETF draft, and open problems including standard-model binding and universal composability.

Keywords: transaction tokens, token binding, existential unforgeability, random oracle model, OAuth, SPT-Txn.

Contents

1 Introduction **2**
- 1.1 Opening Problem Statement . . . 2
- 1.2 This Work . . . 2
- 1.3 Contributions . . . 2
- 1.4 Scope and Limitations . . . 3
- 1.5 Paper Organization . . . 3

2 Preliminaries **3**
- 2.1 Notation . . . 3
- 2.2 Digital Signature Schemes . . . 4
- 2.3 The Random Oracle Model . . . 4
- 2.4 Transaction Context Space . . . 4
- 2.5 Claims Space . . . 5

3 SPT-Txn Construction **5**
- 3.1 Building Blocks . . . 5
- 3.2 Algorithm Specifications . . . 5
- 3.3 Correctness . . . 6

4 Security Definitions **6**
- 4.1 Adversary Model . . . 6
- 4.2 Definition 1: Transaction Binding . . . 6
- 4.3 Definition 2: Existential Unforgeability Under Chosen-Context Attack . . . 7
- 4.4 Definition 3: Unlinkability . . . 7
- 4.5 Property Hierarchy . . . 8

5 Main Result **8**

6 Discussion **10**
- 6.1 Scope of the Security Model . . . 10
- 6.2 Implementation Alignment with the IETF Draft . . . 10
- 6.3 Extensions . . . 11
- 6.4 Open Problems . . . 11
- 6.5 Relationship to Prior Work . . . 11

1 Introduction

1.1 Opening Problem Statement

Authorization in distributed systems has long relied on bearer tokens — cryptographically signed assertions that any holder may present to gain access. The dominant deployed standard, OAuth 2.0 [7], treats tokens as context-free objects: a token issued for one purpose is structurally identical to a token issued for another, and its validity is independent of the transaction in which it is presented. This design is adequate for coarse-grained access control but breaks down in environments where authorization must be scoped to a specific transaction and where the reuse of a valid token across transaction boundaries constitutes a security violation.

The problem is not hypothetical. In regulated financial infrastructure, cross-border payment authorization, and decentralized asset transfer protocols, a token that successfully authorizes one transaction must be provably incapable of authorizing a different one — even when the token is cryptographically intact and the presenting party is otherwise legitimate. This is a binding requirement: the authorization evidence must be inseparably coupled to the transaction context for which it was issued.

Despite the practical urgency of this requirement, no formal security model for transaction-scoped policy enforcement tokens exists in the literature. The IETF Transaction Tokens specification [12] defines a systems architecture for scoped tokens but provides no cryptographic security proof. OAuth 2.0 Demonstrating Proof of Possession (DPoP, [11]) binds tokens to a key pair but not to a transaction context. Macaroons [3] provide contextual caveats via HMAC chaining but operate under a shared-secret model and lack a formal binding proof. The result is a persistent gap between deployed token architectures and the cryptographic foundations that would justify confidence in their security guarantees.

This paper closes that gap for a specific, well-defined setting.

1.2 This Work

We introduce the first formal security model for policy-bound transaction tokens and prove that a concrete construction achieves transaction binding security under standard cryptographic assumptions.

Our model is grounded in the Sovereign Policy Token Transaction (SPT-Txn) Framework — a token architecture for policy-bound, tamper-evident authorization across trust boundaries, specified concurrently in IETF Internet-Draft `draft-coetzee-oauth-spt-txn-tokens` [5]. The central object is a Capability Acquisition Token (CAT): a token issued by an authorization server, cryptographically bound to a transaction context $\mathsf{ctx} = (\mathsf{txid}, \pi, t, \mathsf{meta})$, and verifiable by any party holding the issuer's public key without issuer interaction.

The central security question is: *can a CAT issued for one transaction be presented, without detection, as authorization for a different transaction?* We answer this question formally by defining transaction binding security as a game-based security property, constructing a scheme $\Pi[\Sigma, H]$ that achieves it, and proving security under the EUF-CMA assumption on the underlying signature scheme Σ in the random oracle model.

1.3 Contributions

We make the following contributions:

1. **Formal syntax for policy-bound transaction tokens.** We define the algorithm tuple $(\mathsf{Setup}, \mathsf{KeyGen}, \mathsf{Issue}, \mathsf{Verify})$ for transaction token schemes, including a formal definition of the transaction context space $\mathcal{C}$ and the injectivity requirement on canonical context encodings. This syntax is the first formal treatment of the SPT-Txn token structure.

2. **Game-based security definitions.** We define three security properties for transaction token schemes: *transaction binding (TB)*, capturing resistance to both forgery and cross-context reuse in a single game; *existential unforgeability under chosen-context attack (EUF-CCA)*, isolating pure forgery resistance; and *unlinkability (UNL)*, capturing token pseudonymity. We establish the strict implication $\mathsf{TB} \implies \mathsf{EUF\text{-}CCA}$ and clarify the fundamental tension between unlinkability and auditability in this setting.

3. **A construction and tight security proof.** We present $\Pi[\Sigma, H]$, a construction parameterized by any EUF-CMA-secure signature scheme Σ and a random oracle H. We prove in Theorem 5.1 that $\Pi[\Sigma, H]$ is transaction-binding secure with advantage bound:

$$\mathsf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda) \;\leq\; \mathsf{Adv}_{\Sigma}^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) \;+\; \frac{(q_s + q_H)^2}{2^\lambda}.$$

The reduction is tight — $\mathcal{B}$ runs in essentially the same time as $\mathcal{A}$ with no rewinding. EUF-CCA security follows as Corollary 5.2.

1.4 Scope and Limitations

The model assumes a single honest issuer and a static adversary who cannot compromise the signing key or observe key rotation events. We do not model token revocation, multi-issuer federation, or concurrent composition. The proof is in the random oracle model — whether transaction binding security is achievable under standard model assumptions is left as an open problem (Section 6.4). These limitations are not deficiencies of the construction; they are honest boundaries of the present analysis, each of which points to a concrete direction for future work.

1.5 Paper Organization

Section 2 establishes notation, defines EUF-CMA security, introduces the random oracle model, and formally defines the transaction context space $\mathcal{C}$. Section 3 specifies the SPT-Txn construction $\Pi[\Sigma, H]$ and proves correctness. Section 4 defines the three security properties as formal games and establishes their hierarchy. Section 5 states and proves the main result, Theorem 5.1, together with Corollary 5.2 and Remark 5.1. Section 6 discusses scope limitations, implementation alignment with the IETF draft, extensions, open problems, and related work.

2 Preliminaries

2.1 Notation

Let $\lambda \in \mathbb{N}$ denote the security parameter. A function $f : \mathbb{N} \to \mathbb{R}_{\geq 0}$ is *negligible*, written $f(\lambda) = \mathsf{negl}(\lambda)$, if for every polynomial p there exists λ_0 such that $f(\lambda) < 1/p(\lambda)$ for all $\lambda > \lambda_0$. A function is *overwhelming* if $1 - f(\lambda) = \mathsf{negl}(\lambda)$.

All algorithms are modeled as *probabilistic polynomial-time (PPT)* Turing machines unless stated otherwise. We write $y \leftarrow \mathcal{A}(x)$ to denote running algorithm $\mathcal{A}$ on input x with fresh randomness and assigning the output to y. We write $y \leftarrow S$ to denote sampling y uniformly at random from a finite set S. We write $y := f(x)$ for deterministic assignment.

For strings $a, b \in \{0,1\}^*$ we write $a \| b$ for concatenation; $|a|$ denotes bit length.

Game-based security. A security game $\mathsf{G}(\mathcal{A}, \lambda)$ is an interaction between a challenger $\mathcal{C}$ and an adversary $\mathcal{A}$, terminating in a bit output. The *advantage* of $\mathcal{A}$ in game G is:

$$\mathsf{Adv}^{\mathsf{G}}(\mathcal{A}, \lambda) := \Pr[\mathsf{G}(\mathcal{A}, \lambda) = 1].$$

A scheme satisfies a security property if $\mathsf{Adv}^{\mathsf{G}}(\mathcal{A}, \lambda) = \mathsf{negl}(\lambda)$ for all PPT $\mathcal{A}$.

2.2 Digital Signature Schemes

Definition 2.1 (Digital Signature Scheme)**.** *A* digital signature scheme *is a triple of PPT algorithms* $\Sigma = (\mathsf{SigKeyGen}, \mathsf{Sign}, \mathsf{SigVerify})$*:*

- $\mathsf{SigKeyGen}(1^\lambda) \to (pk, sk)$*: outputs a public verification key* pk *and secret signing key* sk*.*
- $\mathsf{Sign}(sk, m) \to \sigma$*: on input a signing key and message* $m \in \{0,1\}^*$*, outputs a signature* σ*.*
- $\mathsf{SigVerify}(pk, m, \sigma) \to \{0,1\}$*: outputs an accept/reject bit.*

Definition 2.2 (Correctness)**.** Σ *is* correct *if for all* $\lambda \in \mathbb{N}$*, all* $(pk, sk) \leftarrow \mathsf{SigKeyGen}(1^\lambda)$*, and all* $m \in \{0,1\}^*$*:*

$$\Pr[\mathsf{SigVerify}(pk, m, \mathsf{Sign}(sk, m)) = 1] = 1.$$

Definition 2.3 (EUF-CMA Security)**.** Σ *is* existentially unforgeable under chosen-message attack (EUF-CMA) *if for all PPT adversaries* $\mathcal{B}$ *the advantage in the following game is negligible in* λ*:*

Game EUF-CMA$(\mathcal{B}, \lambda)$

$$\begin{aligned}
&(pk, sk) \leftarrow \mathsf{SigKeyGen}(1^\lambda)\\
&(m^*, \sigma^*) \leftarrow \mathcal{B}^{\mathcal{O}_{\mathsf{Sign}}(sk,\cdot)}(pk)\\
&\textit{Return } 1 \iff \mathsf{SigVerify}(pk, m^*, \sigma^*) = 1 \wedge m^* \notin Q_{\mathsf{sign}}
\end{aligned}$$

where $Q_{\mathsf{sign}} = \{m_i\}$ *is the set of messages submitted by* $\mathcal{B}$ *to the signing oracle* $\mathcal{O}_{\mathsf{Sign}}$*.*

2.3 The Random Oracle Model

The *random oracle model (ROM)* [1] is an idealized model of computation in which a hash function $H : \{0,1\}^* \to \{0,1\}^\lambda$ is replaced by a truly random function, accessible to all parties — including the adversary — only through oracle queries. Each query $H(x)$ returns a uniformly random value in $\{0,1\}^\lambda$, consistent across repeated queries on the same input.

The ROM serves two roles in this paper. First, it provides collision resistance for variable-length context encodings: the birthday bound gives collision probability at most $(q_s + q_H)^2/2^\lambda$ over q_s signing queries and q_H hash queries, which is $\mathsf{negl}(\lambda)$ for polynomially bounded query counts. Second, it ensures that the hash output $H(\mathsf{enc}(\mathsf{ctx}) \| \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$ is uniformly distributed and independent of the adversary's view prior to the query, which is essential for the simulation argument in the proof of Theorem 5.1.

In the security games of §4 and the reduction of §5, the challenger simulates H via a *lazy sampling table* $T : \{0,1\}^* \to \{0,1\}^\lambda$: on query x, if $T[x]$ is undefined, sample $h \leftarrow \{0,1\}^\lambda$ and set $T[x] \leftarrow h$; return $T[x]$. This simulation is perfect.

2.4 Transaction Context Space

The *transaction context space* $\mathcal{C}$ is the domain over which SPT-Txn tokens are bound. We define it formally here as it is the central object distinguishing SPT-Txn from generic signature-based token schemes.

Definition 2.4 (Transaction Context)**.** *A* transaction context *is a tuple*

$$\mathsf{ctx} = (\mathsf{txid},\ \pi,\ t,\ \mathsf{meta}) \ \in\ \mathcal{C}$$

where:

Field	*Domain*	*Semantics*
txid	$\{0,1\}^{2\lambda}$	*Globally unique transaction identifier*
π	$\{0,1\}^*$	*Serialized policy set*
t	$\mathbb{Z}_{\geq 0}$	*Issuance timestamp (Unix epoch)*
meta	$\{0,1\}^*$	*Subject, scope, trust domain*

The context ctx *is* publicly known at verification time. *The binding security property captures the requirement that a token cannot travel across contexts, not that the context itself is hidden.*

Definition 2.5 (Canonical Encoding)**.** *Let* $\mathsf{enc} : \mathcal{C} \to \{0,1\}^*$ *be a* canonical, injective encoding *of transaction contexts:*

$$\mathsf{enc}(\mathsf{ctx}_0) = \mathsf{enc}(\mathsf{ctx}_1) \implies \mathsf{ctx}_0 = \mathsf{ctx}_1.$$

This is achievable via any length-prefixed serialization (e.g., TLV encoding or canonical CBOR [10]). Similarly, let $\mathsf{enc}_{\mathsf{cls}} : \mathcal{CLS} \to \{0,1\}^*$ *be a canonical injective encoding of the claims space* $\mathcal{CLS}$*.*

Remark 2.1 (Role of Injectivity)**.** *The injectivity of* enc *is load-bearing in the proof of Theorem 5.1. It ensures that* $\mathsf{ctx}_0 \neq \mathsf{ctx}_1$ *implies* $\mathsf{enc}(\mathsf{ctx}_0) \neq \mathsf{enc}(\mathsf{ctx}_1)$*, so that a ROM collision is the only path by which two distinct contexts could produce the same hash input. Without injectivity, an adversary could construct encoding collisions in the clear, entirely bypassing the random oracle argument.*

2.5 Claims Space

The *claims space* $\mathcal{CLS}$ contains the policy assertions carried by a CAT. Claims are opaque to the security model — the proof treats cls as an arbitrary bitstring in $\{0,1\}^*$ and makes no assumptions about its internal structure. This is intentional: the binding security property holds regardless of claims content, which is a strength of the construction.

3 SPT-Txn Construction

3.1 Building Blocks

The construction $\Pi[\Sigma, H]$ is parameterized by two primitives:

- $\Sigma = (\mathsf{SigKeyGen}, \mathsf{Sign}, \mathsf{SigVerify})$ — a digital signature scheme (Definition 2.1).
- $H : \{0,1\}^* \to \{0,1\}^\lambda$ — a hash function modeled as a random oracle (§2).

The binding security of the scheme reduces entirely to the unforgeability of Σ. The random oracle H handles variable-length context serialization and provides collision resistance. No additional primitives are required, keeping the assumption footprint minimal.

3.2 Algorithm Specifications

$\mathsf{Setup}(1^\lambda) \to \mathsf{pp}$**.**

$$\mathsf{pp} := (1^\lambda,\ \mathcal{C},\ \mathcal{CLS},\ \mathsf{enc},\ \mathsf{enc}_{\mathsf{cls}},\ H).$$

$\mathsf{KeyGen}(\mathsf{pp}) \to (pk, sk)$**.**

$$(pk, sk) \leftarrow \Sigma.\mathsf{SigKeyGen}(1^\lambda).$$

The issuer holds sk; verifiers hold pk.

$\mathsf{Issue}(sk, \mathsf{ctx}, \mathsf{cls}) \to \tau$.

1. $m \leftarrow H(\mathsf{enc}(\mathsf{ctx}) \parallel \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$
2. $\sigma \leftarrow \Sigma.\mathsf{Sign}(sk,\ m)$
3. Output $\tau := (\sigma,\ \mathsf{cls})$

Design note. The verifier reconstructs m independently using cls (carried in τ) and ctx (known at verification time). Including ctx in τ would be redundant and expand token size without security benefit. The context is the binding surface, not token payload.

$\mathsf{Verify}(pk, \tau, \mathsf{ctx}) \to \{0, 1\}$.

1. $(\sigma, \mathsf{cls}) \leftarrow \tau$
2. $m \leftarrow H(\mathsf{enc}(\mathsf{ctx}) \parallel \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$
3. Return $\Sigma.\mathsf{SigVerify}(pk,\ m,\ \sigma)$

Verification is fully stateless and requires no issuer interaction.

3.3 Correctness

Lemma 3.1 (Correctness). *For all $\lambda \in \mathbb{N}$, all $\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$, all $(pk, sk) \leftarrow \mathsf{KeyGen}(\mathsf{pp})$, and all $(\mathsf{ctx}, \mathsf{cls}) \in \mathcal{C} \times \mathcal{CLS}$:*

$$\Pr[\mathsf{Verify}(pk, \mathsf{Issue}(sk, \mathsf{ctx}, \mathsf{cls}), \mathsf{ctx}) = 1] = 1.$$

Proof. Issue produces $\sigma \leftarrow \Sigma.\mathsf{Sign}(sk, m)$ and Verify reconstructs the identical m from the same $(\mathsf{ctx}, \mathsf{cls})$, then calls $\Sigma.\mathsf{SigVerify}(pk, m, \sigma)$. Correctness of Σ (Definition 2.1) guarantees this returns 1. □

4 Security Definitions

4.1 Adversary Model

The adversary $\mathcal{A}$ is a PPT algorithm operating under the following threat model. $\mathcal{A}$ holds the issuer's public key pk but not sk. It has adaptive oracle access $\mathcal{A}^{\mathcal{O}_{\mathsf{Issue}}(sk,\cdot,\cdot)}$ to issue tokens for contexts and claims of its choice, modelling a compromised or cooperative relying party. The signing key is not exposed; key compromise is outside the scope of this model (see §6.1).

The oracle call record is:

$$Q = \left\{(\mathsf{ctx}_i,\ \mathsf{cls}_i,\ \tau_i)\right\}_{i=1}^{q_s} \quad \text{where} \quad \tau_i = \mathsf{Issue}(sk, \mathsf{ctx}_i, \mathsf{cls}_i).$$

4.2 Definition 1: Transaction Binding

Definition 4.1 (Transaction Binding Security).

Game $\mathsf{TB}(\mathcal{A}, \lambda)$

$$
\begin{aligned}
&\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda) \\
&(pk, sk) \leftarrow \mathsf{KeyGen}(\mathsf{pp}) \\
&(\tau^*, \mathsf{ctx}^*) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{Issue}}(sk,\cdot,\cdot)}(pk) \\
&\textit{Return } 1 \iff \\
&\quad (1)\ \mathsf{Verify}(pk, \tau^*, \mathsf{ctx}^*) = 1 \\
&\quad (2)\ \tau^* \notin \{\tau_i : \mathsf{ctx}_i = \mathsf{ctx}^*\}
\end{aligned}
$$

Condition (2) is the non-trivial win condition*: τ^* was not a direct* Issue *output for* ctx^**. This collapses two attack vectors:*

- ***Forgery attack****: τ^* is freshly constructed with no prior oracle query for* ctx^**.*
- ***Reuse attack****: τ^* was issued for some* $\mathsf{ctx}' \neq \mathsf{ctx}^*$ *and $\mathcal{A}$ presents it under* ctx^**.*

The advantage is $\mathsf{Adv}_\Pi^{\mathsf{TB}}(\mathcal{A}, \lambda) := \Pr[\mathsf{TB}(\mathcal{A}, \lambda) = 1]$*. A scheme Π is* transaction-binding secure *if* $\mathsf{Adv}_\Pi^{\mathsf{TB}}(\mathcal{A}, \lambda) = \mathsf{negl}(\lambda)$ *for all PPT $\mathcal{A}$.*

4.3 Definition 2: Existential Unforgeability Under Chosen-Context Attack

Definition 4.2 (EUF-CCA Security)**.**

Game $\mathsf{EUF\text{-}CCA}(\mathcal{A}, \lambda)$

$$
\begin{aligned}
&\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda) \\
&(pk, sk) \leftarrow \mathsf{KeyGen}(\mathsf{pp}) \\
&(\tau^*, \mathsf{ctx}^*) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{Issue}}(sk,\cdot,\cdot)}(pk) \\
&\textit{Return } 1 \iff \\
&\quad (1)\ \mathsf{Verify}(pk, \tau^*, \mathsf{ctx}^*) = 1 \\
&\quad (2)\ \mathsf{ctx}^* \notin \{\mathsf{ctx}_i\}
\end{aligned}
$$

Here condition (2) requires ctx^* *to have been* never queried *— the adversary wins only by forging for a completely fresh context.* TB *is strictly stronger: it also catches reuse against queried contexts.*

A scheme Π is EUF-CCA secure *if* $\mathsf{Adv}_\Pi^{\mathsf{EUF\text{-}CCA}}(\mathcal{A}, \lambda) = \mathsf{negl}(\lambda)$ *for all PPT $\mathcal{A}$.*

4.4 Definition 3: Unlinkability

Definition 4.3 (Unlinkability)**.**

Game UNL($\mathcal{A}, \lambda$)

$$\begin{aligned}
&\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda) \\
&(pk, sk) \leftarrow \mathsf{KeyGen}(\mathsf{pp}) \\
&(\mathsf{ctx}_0, \mathsf{ctx}_1, \mathsf{cls}_0, \mathsf{cls}_1) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{Issue}}}(pk) \\
&b \leftarrow \{0,1\}; \quad \tau_b \leftarrow \mathsf{Issue}(sk, \mathsf{ctx}_b, \mathsf{cls}_b) \\
&b' \leftarrow \mathcal{A}(\tau_b) \\
&\textit{Return } 1 \iff b' = b
\end{aligned}$$

The advantage is $|\Pr[b' = b] - 1/2|$.
A scheme Π *is* unlinkable *if* $\mathsf{Adv}^{\mathsf{UNL}}_{\Pi}(\mathcal{A}, \lambda) = \mathsf{negl}(\lambda)$ *for all PPT* $\mathcal{A}$.

Remark 4.1. *Unlinkability and auditability are fundamentally opposed under the same key material. A scheme satisfying both simultaneously requires either a blind issuance mechanism or a separate auditor key. For SPT-Txn, auditability is primary; unlinkability is achievable via the randomized variant described in Remark 5.1.*

4.5 Property Hierarchy

Proposition 4.1 (TB $\implies$ EUF-CCA)**.** *Transaction binding security strictly implies EUF-CCA security. The converse does not hold.*

Proof. Any PPT adversary winning EUF-CCA — producing a valid token for a fresh context $\mathsf{ctx}^* \notin \{\mathsf{ctx}_i\}$ — trivially satisfies condition (2) of game TB. Hence its TB advantage is at least its EUF-CCA advantage, giving the forward implication.

For the converse: a scheme can be EUF-CCA secure yet fail TB. Suppose Verify ignores the context field entirely and accepts any well-signed token; then no fresh forgery is possible (EUF-CCA holds) but any issued token can be freely reused across contexts (TB fails). □

The main theorem target is therefore TB; EUF-CCA is a corollary.

5 Main Result

Theorem 5.1 (Transaction Binding Security)**.** *Let* Σ *be an EUF-CMA-secure digital signature scheme and let* H *be a hash function modeled as a random oracle. Then the construction* $\Pi[\Sigma, H]$ *is transaction-binding secure. Specifically, for any PPT adversary* $\mathcal{A}$ *making at most* q_s *signing oracle queries and* q_H *random oracle queries:*

$$\mathsf{Adv}^{\mathsf{TB}}_{\Pi}(\mathcal{A}, \lambda) \;\le\; \mathsf{Adv}^{\mathsf{EUF\text{-}CMA}}_{\Sigma}(\mathcal{B}, \lambda) \;+\; \frac{(q_s + q_H)^2}{2^\lambda}$$

where $\mathcal{B}$ *is a PPT adversary against* Σ *with essentially the same running time as* $\mathcal{A}$.

Proof. We construct a reduction $\mathcal{B}$ that uses any PPT $\mathcal{A}$ winning game TB to break EUF-CMA of Σ.

Setup. $\mathcal{B}$ receives (pk, pp) from its EUF-CMA challenger, forwards pk to $\mathcal{A}$, and maintains a lazy sampling table $T : \{0,1\}^* \to \{0,1\}^\lambda$ to simulate H.

Oracle simulation. $\mathcal{B}$ simulates both oracles perfectly:

- *Random oracle* $\mathcal{O}_H(x)$: If $T[x]$ is undefined, sample $h \leftarrow \{0,1\}^\lambda$ and set $T[x] := h$. Return $T[x]$.

- *Issue oracle* $\mathcal{O}_{\mathsf{Issue}}(\mathsf{ctx}_i, \mathsf{cls}_i)$: Compute $m_i \leftarrow \mathcal{O}_H(\mathsf{enc}(\mathsf{ctx}_i) \| \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_i))$. Query $\mathcal{B}$'s own signing oracle to obtain $\sigma_i \leftarrow \Sigma.\mathsf{Sign}(sk, m_i)$. Return $\tau_i := (\sigma_i, \mathsf{cls}_i)$ and record $(\mathsf{ctx}_i, \mathsf{cls}_i, m_i, \sigma_i)$ in $\log Q$.

$\mathcal{A}$'s view is identically distributed to the real TB game.

Extraction. When $\mathcal{A}$ outputs (τ^*, ctx^*), parse $\tau^* = (\sigma^*, \mathsf{cls}^*)$ and compute $m^* \leftarrow \mathcal{O}_H(\mathsf{enc}(\mathsf{ctx}^*) \| \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}^*))$.

Since $\mathcal{A}$ wins TB:

$$\mathsf{Verify}(pk, \tau^*, \mathsf{ctx}^*) = 1 \implies \Sigma.\mathsf{SigVerify}(pk, m^*, \sigma^*) = 1,$$

and $\tau^* \notin \{\tau_i : \mathsf{ctx}_i = \mathsf{ctx}^*\}$.

We consider two mutually exhaustive cases.

Case 1 — Forgery attack. $\mathsf{ctx}^* \notin \{\mathsf{ctx}_i\}$: $\mathcal{A}$ never queried Issue on ctx^*. Suppose for contradiction that $m^* = m_j$ for some $j \in Q$. Then:

$$H(\mathsf{enc}(\mathsf{ctx}^*) \| \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}^*)) = H(\mathsf{enc}(\mathsf{ctx}_j) \| \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_j)).$$

Since $\mathsf{ctx}^* \notin \{\mathsf{ctx}_i\}$ and enc is injective (Definition 2.5), $\mathsf{enc}(\mathsf{ctx}^*) \neq \mathsf{enc}(\mathsf{ctx}_j)$ for all j, so the pre-images differ. This is a ROM collision, occurring with probability at most $(q_s + q_H)^2/2^\lambda$ by the birthday bound.

Therefore, except with probability $(q_s + q_H)^2/2^\lambda$, m^* was never submitted to $\mathcal{B}$'s signing oracle. $\mathcal{B}$ outputs (m^*, σ^*) as its EUF-CMA forgery.

Case 2 — Reuse attack. τ^* was issued for some queried $\mathsf{ctx}' \neq \mathsf{ctx}^*$. There exists $j \in Q$ with $\tau^* = \tau_j$ and $\mathsf{ctx}_j \neq \mathsf{ctx}^*$. $\mathcal{B}$ holds σ_j from $\Sigma.\mathsf{Sign}(sk, m_j)$ where $m_j = H(\mathsf{enc}(\mathsf{ctx}_j) \| \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_j))$.

For $\Sigma.\mathsf{SigVerify}(pk, m^*, \sigma_j) = 1$ to hold with $m^* \neq m_j$, σ_j is a valid signature under a message distinct from its signing input — a direct EUF-CMA break.

We confirm $m^* \neq m_j$ except negligibly: $\mathsf{ctx}^* \neq \mathsf{ctx}_j$ and enc is injective, so $\mathsf{enc}(\mathsf{ctx}^*) \neq \mathsf{enc}(\mathsf{ctx}_j)$; thus $m^* = m_j$ requires an H-collision, probability at most $(q_s + q_H)^2/2^\lambda$.

$\mathcal{B}$ outputs (m^*, σ_j) as its EUF-CMA forgery.

Accounting. In both cases, $\mathcal{B}$ outputs a valid message-signature pair (m^*, σ^*) where m^* was not submitted to $\mathcal{B}$'s own signing oracle, except with probability $(q_s + q_H)^2/2^\lambda$. $\mathcal{B}$ makes exactly q_s signing oracle calls — one per Issue query — within the EUF-CMA polynomial bound. The running time of $\mathcal{B}$ is that of $\mathcal{A}$ plus $O(q_s + q_H)$ table operations.

Therefore:

$$\mathsf{Adv}_\Pi^{\mathsf{TB}}(\mathcal{A}, \lambda) \leq \mathsf{Adv}_\Sigma^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) + \frac{(q_s + q_H)^2}{2^\lambda}.$$

Since $\mathsf{Adv}_\Sigma^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) = \mathsf{negl}(\lambda)$ by assumption and $(q_s + q_H)^2/2^\lambda = \mathsf{negl}(\lambda)$ for polynomial q_s, q_H, we conclude $\mathsf{Adv}_\Pi^{\mathsf{TB}}(\mathcal{A}, \lambda) = \mathsf{negl}(\lambda)$. □

Corollary 5.2 (EUF-CCA Security)**.** *Under the same assumptions as Theorem 5.1,* $\Pi[\Sigma, H]$ *is EUF-CCA secure.*

Proof. By Theorem 5.1 and Proposition 4.1. Any PPT adversary winning $\mathsf{EUF\text{-}CCA}$ satisfies the TB win condition directly, so its advantage is bounded by Theorem 5.1. □

Remark 5.1 (Randomized Variant and Unlinkability)**.** *The construction* $\Pi[\Sigma, H]$ *is deterministic: two calls to* $\mathsf{Issue}(sk, \mathsf{ctx}, \mathsf{cls})$ *with identical inputs produce identical tokens. This is sufficient for transaction binding and EUF-CCA security but precludes unlinkability (Definition 4.3) when* $\mathsf{cls}_0 = \mathsf{cls}_1$.

A randomized variant replaces the hash input with $\mathsf{enc}(\mathsf{ctx}) \| \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}) \| r$ *where* $r \leftarrow \{0,1\}^\lambda$ *is fresh per issuance, with* r *included in* τ. *The proof of Theorem 5.1 is unchanged since* r *participates identically in both* Issue *and* Verify. *The variant achieves unlinkability in the ROM,*

since the hash output is uniformly random and independent across tokens even when contexts and claims coincide.

For SPT-Txn deployments where auditability is the primary requirement, the deterministic construction is preferred. The randomized variant is appropriate where token pseudonymity is needed alongside binding. Implementation considerations are discussed in §6.2.

6 Discussion

6.1 Scope of the Security Model

The security model of Sections 4 and 5 is deliberately narrow.

Honest issuer. The model assumes an honest issuer holding sk throughout. Key compromise falls under a separate forward security analysis, which is orthogonal to the binding property proved here. A natural extension replaces Σ with a key-evolving signature scheme in the style of Bellare and Miner [2], providing forward security after key rotation events.

Single issuer. The construction assumes a single issuer key pair. Real SPT-Txn deployments involve multi-party issuance: federated authorization servers, delegated policy authorities, and cross-domain trust. Multi-issuer settings require a formal trust hierarchy definition and a binding game that accounts for cross-issuer forgery. This is left as future work.

No revocation. The model has no revocation oracle. Token revocation in high-throughput transaction environments is an orthogonal systems problem. The binding property proved here is necessary but not sufficient for a complete token lifecycle security analysis.

Static adversary. The adversary receives pk at the start and cannot update its strategy based on key rotation. Dynamic adversaries observing key transitions are out of scope.

No timing or side-channel model. The proof is in the computational model only. In practice, implementations should use constant-time algorithms; EdDSA over Ed25519 satisfies this requirement.

6.2 Implementation Alignment with the IETF Draft

The construction $\Pi[\Sigma, H]$ is abstract over any EUF-CMA-secure Σ. For the concrete deployment described in `draft-coetzee-oauth-spt-txn-tokens-00` [5], the instantiation is:

- Σ: EdDSA over Ed25519 [9], EUF-CMA secure under the discrete logarithm assumption.
- H: SHA-256, giving $\lambda = 256$ and a 128-bit security level.
- **Token format**: JWS compact serialization [8].
- **Canonical encoding**: CBOR [10], injective by construction, satisfying Definition 2.5.

The collision bound $(q_s + q_H)^2/2^{256}$ is negligible for any polynomially bounded adversary, consistent with NIST guidance for 128-bit equivalent security.

Note on token expiry. The IETF draft specifies a lifetime field t_{exp} in meta. The formal model treats t as an issuance timestamp only. Expiry is an enforcement policy applied at the verifier and does not affect the binding security proof; a complete implementation must enforce expiry outside the cryptographic core.

6.3 Extensions

Threshold issuance. The signing key sk can be replaced by a (t, n)-threshold signature scheme without affecting the proof, provided the threshold scheme is EUF-CMA secure. The signing oracle in the TB game becomes a threshold signing oracle; the reduction proceeds identically.

Forward security. Replacing Σ with a forward-secure signature scheme [2] provides temporal isolation of token validity periods. The binding proof extends directly since the EUF-CMA reduction makes no assumption about the internal structure of $\mathsf{SigKeyGen}$ beyond correctness and unforgeability.

Attribute-selective disclosure. The current construction commits to the full claims set cls atomically. A selective disclosure extension — presenting a subset $\mathsf{cls}' \subseteq \mathsf{cls}$ while proving issuer authorization — requires replacing the flat hash commitment with a Merkle tree or vector commitment scheme, and introducing a corresponding *selective binding* game. This extension requires a separate security definition and proof and is left as future work.

Batch verification. In high-throughput environments a verifier may receive many tokens for the same pk simultaneously. EdDSA supports batch verification in $O(n)$ group operations rather than $O(n)$ individual verifications, without affecting the security proof.

6.4 Open Problems

Open Problem 1: Standard model binding security. Theorem 5.1 is proved in the random oracle model. Whether transaction binding security is achievable under standard model assumptions remains open. The difficulty is handling the cross-context reuse case without ROM independence. A standard model construction would likely require a programmable hash function or chameleon hash.

Open Problem 2: Universal composability. The proof is in the standalone model. Whether $\Pi[\Sigma, H]$ is secure under concurrent composition — relevant when a single authorization server issues tokens across many concurrent transactions — is not addressed. A UC treatment [4] of SPT-Txn binding security would resolve this.

Open Problem 3: Policy binding. The current model treats the policy field $\pi \in \mathsf{ctx}$ as an opaque bitstring. A richer definition would capture *policy soundness*: a token issued under policy π cannot authorize actions outside the scope of π, even under partial verifier compromise. Formalizing this requires a policy semantics layer above the cryptographic model, connecting the token binding proof to an access control logic.

6.5 Relationship to Prior Work

OAuth 2.0 and RFC 9700. Standard OAuth 2.0 bearer tokens [7] provide no binding. Transaction Tokens [12] introduce audience binding without a formal proof. The present work provides the first formal security model and proof for transaction-scoped policy binding.

DPoP. DPoP [11] binds tokens to a holder key pair via a proof-of-possession mechanism but does not bind to a transaction context. The binding notion is orthogonal.

Macaroons. Macaroons [3] support contextual caveats via HMAC chaining. The trust model requires a shared secret between issuer and verifier, which SPT-Txn does not. The security analysis for Macaroons is informal.

UCAN. User Controlled Authorization Networks use capability delegation with DID-based keys. The security analysis is informal. SPT-Txn targets a centralized issuer topology with formally verifiable binding guarantees that UCAN currently lacks.

Verifiable Credentials. W3C Verifiable Credentials provide cryptographic integrity for claims but do not address transaction binding. The claims space $\mathcal{CLS}$ in the SPT-Txn model is compatible with the VC data model, making the systems complementary.

References

[1] M. Bellare and P. Rogaway. Random oracles are practical: A paradigm for designing efficient protocols. In *Proc. 1st ACM CCS*, pages 62–73, 1993.

[2] M. Bellare and S. Miner. A forward-secure digital signature scheme. In *Advances in Cryptology — CRYPTO '99*, LNCS 1666, pages 431–448. Springer, 1999.

[3] A. Birgisson, J. Politz, U. Erlingsson, A. Taly, M. Vrable, and M. Lentczner. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In *Proc. NDSS 2014*, 2014.

[4] R. Canetti. Universally composable security: A new paradigm for cryptographic protocols. In *Proc. 42nd IEEE FOCS*, pages 136–145, 2001.

[5] R.J. Coetzee. SPT-Txn: Sovereign policy token transactions. IETF Internet-Draft `draft-coetzee-oauth-spt-txn-tokens-00`, 2026. Work in progress.

[6] R.J. Coetzee. The SPT-Txn framework: Policy-bound transaction token architecture. Zenodo preprint, DOI: 10.5281/zenodo.18917439, 2026.

[7] M. Jones and D. Hardt. RFC 6750: The OAuth 2.0 authorization framework: Bearer token usage. *IETF RFC*, 2012.

[8] M. Jones, J. Bradley, and N. Sakimura. RFC 7515: JSON web signature (JWS). *IETF RFC*, 2015.

[9] S. Josefsson and I. Liusvaara. RFC 8032: Edwards-curve digital signature algorithm (EdDSA). *IETF RFC*, 2017.

[10] C. Bormann and P. Hoffman. RFC 8949: Concise binary object representation (CBOR). *IETF RFC*, 2020.

[11] F. Fett, B. Campbell, J. Bradley, T. Lodderstedt, M. Jones, and D. Waite. RFC 9449: OAuth 2.0 demonstrating proof of possession (DPoP). *IETF RFC*, 2023.

[12] A. Tulshibagwale, G. Fletcher, P. Kasselman, K. Burgin, and D. Richer. RFC 9700: Transaction tokens. *IETF RFC*, 2025.